Sécurité des API — correspondance OWASP API Security Top 10

Référentiel : OWASP API Security Top 10, édition 2023. La gateway est la seule entrée publique ; chaque service revalide le jeton. Chaque ligne cite un test du dépôt : ils tournent en CI (jobs `gateway`, `underwriting-admin`, `test`, `integration`).

Risque	Protection	Tests
API1 · Autorisation au niveau objet (BOLA)	Chaque lecture filtre par `gestionnaire_id`, l'`oid` du jeton. Un dossier d'un autre répond 404, comme un dossier inexistant.	`ContratsTests.Contrat_autre_gestionnaire_et_inexistant_meme_reponse` ; `test_api_cluster.py::test_bola_un_autre_gestionnaire_ne_voit_ni_ne_reprend_le_dossier_en_pause`, `::test_pause_autre_gestionnaire_404`
API2 · Authentification	Signature, émetteur, audience et date du jeton sont vérifiés par la gateway et par chaque service.	`AutorisationTests.Jeton_signe_par_une_autre_cle_401`, `.Jeton_expire_401`, `.Emetteur_d_un_autre_tenant_401`, `.Audience_d_un_autre_service_403` ; `test_api_cluster.py::test_jeton_d_audience_mcp_401`
API3 · Autorisation au niveau propriété	Le compte `dossiers` ne lit que la vue minimisée ; les routes rendent des DTO dédiés. Un motif de revue qui contient une donnée personnelle est refusé (422).	`test_api_cluster.py::test_motif_avec_donnee_personnelle_422_sans_reprendre_la_revue`
API4 · Consommation de ressources	Limites par route et par appelant, par exemple 10 évaluations par fenêtre, puis 429 avec `Retry-After`. Budget de 25 s par évaluation et budget de tokens par agent.	`ClusterTests.Au_dela_de_la_limite_429_RetryAfter`, `DebitTests.Au_dela_de_la_limite_globale_429_RetryAfter_ProblemDetails` ; `test_api_cluster.py::test_budget_depasse_dans_un_agent_revue_humaine_cause_duree` ; `test_agents.py::test_budget_tokens_repli_cause_distincte`
API5 · Autorisation au niveau fonction	Rôle exigé par route. Les routes internes du cluster ne sont pas exposées, et un verbe inattendu répond 405 sans appeler le service.	`ClusterTests.Les_routes_internes_du_cluster_ne_sont_pas_exposees`, `.Autre_verbe_405_sans_appel_backend`, `.Mauvaise_audience_ou_role_403`
API8 · Mauvaise configuration	Refus par défaut : un chemin inconnu répond 401 sans jeton. CSP stricte sur l'espace gestionnaire.	`AutorisationTests.Chemin_inconnu_401_sans_jeton_404_avec_jeton` ; `EspaceTests.Page_servie_sans_jeton_avec_csp`
API10 · Consommation non sûre d'API tierces	Le LLM est traité comme une source non fiable : garde-fous en entrée et en sortie, puis repli de référence en cas de panne ou de lenteur.	`test_agents.py::test_entree_bloquee_aucun_appel_au_llm_repli_pour_tous`, `::test_pii_en_sortie_cause_garde_fou_pii_jamais_llm_ko`, `::test_lent_none_repli_avec_reference` ; `test_llm_guard.py`

Sans preuve dédiée

Ces risques n'ont pas de test qui leur soit propre. Ils ne sont pas déclarés couverts.

Risque	État
API6 · Flux métier sensibles	Limites de débit (API4) et décision réservée au gestionnaire ; pas d'analyse d'abus dédiée.
API7 · SSRF	Pas d'analyse dédiée.
API9 · Gestion de l'inventaire	Swagger unique et `docs/openapi/` versionnés ; l'OpenAPI de la Function de calcul ne l'est pas.

Limite

Les tests E2E du jeton On-Behalf-Of avec un utilisateur réel tournent depuis le poste, hors CI (`e2e/README.md`). Aucun audit de sécurité externe n'a été mené.